

**IT-SIMPLERA
INSTITUTE**
EMPOWERING MINDS, ELEVATING FUTURES

IT-SIMPLERA INSTITUTE

WEEK 03 ASSIGNMENT REPORT

Topic

Prepared By
Abdul Moiz Zahoor

GitHub: github.com/freakethicall

LinkedIn: [linkedin.com/in/abdul-moiz-zahoor-419933341](https://www.linkedin.com/in/abdul-moiz-zahoor-419933341)

Submitted To
IT-SIMPLERA Institute

Assignment
Week 05 Assignment

Submission Date
31 July 2026

Academic Session
2026

Table of Contents

1. Introduction.....	3
2. Scope	3
3. Tools Used	3
Task 1 - Network Enumeration.....	4
Task 2 - Service Enumeration	9
Task 3 - Vulnerability Research (CVE Analysis).....	10
Task 4 - Scan Comparison.....	11
Task 5 - Security Analysis & Remediation Recommendations	12
Network Diagram - Attack Surface.....	14
Challenges Faced.....	15
Conclusion	16
References.....	17

1. Introduction

This report documents the network enumeration, service discovery, and vulnerability assessment activities performed as part of the Week 5 assignment for the IT-Simplera Cyber Security Analyst Internship Program. The objective of this exercise was to gain hands-on experience with the reconnaissance and enumeration phase of the penetration testing lifecycle, using industry-standard tools to identify open ports, running services, and exploitable vulnerabilities on a deliberately vulnerable lab target.

The assessment follows a structured methodology consistent with real-world vulnerability assessment engagements: scanning, service identification, vulnerability research, comparative analysis of scanning techniques, and the development of practical remediation recommendations mapped to industry frameworks such as NIST, CIS Benchmarks, and OWASP.

2. Scope

- Target System: Metasploitable 2 (intentionally vulnerable Linux virtual machine)
- Target IP Address: 192.168.177.133
- Attacker / Scanning Host: Kali Linux (native dual-boot), IP 192.168.177.128
- Network Environment: VMware Workstation, isolated lab network (192.168.177.0/24)
- Assessment Type: Unauthenticated network enumeration and vulnerability research (no exploitation performed)
- Scanning Tool: Nmap 7.99

3. Tools Used

Tool	Purpose
Kali Linux	Attack/scanning platform used to run all enumeration commands
Nmap 7.99	Network scanning, service/version detection, OS fingerprinting
VMware Workstation	Virtualization platform hosting the isolated lab network
Metasploitable 2	Intentionally vulnerable target VM for enumeration practice
Draw.io / diagram tool	Network topology and attack-surface diagram creation
Microsoft Word	Report compilation and formatting

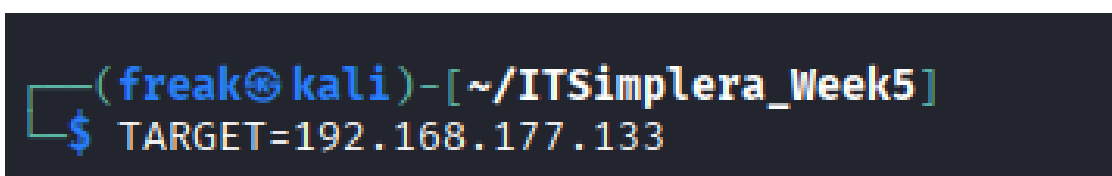
Task 1 — Network Enumeration

Five Nmap scans were performed against the Metasploitable 2 target (192.168.177.133) from the Kali Linux attacker host (192.168.177.128). Each scan was run to completion before the next was started, and output was captured with tee into individual log files for evidence and later analysis.

Commands Executed

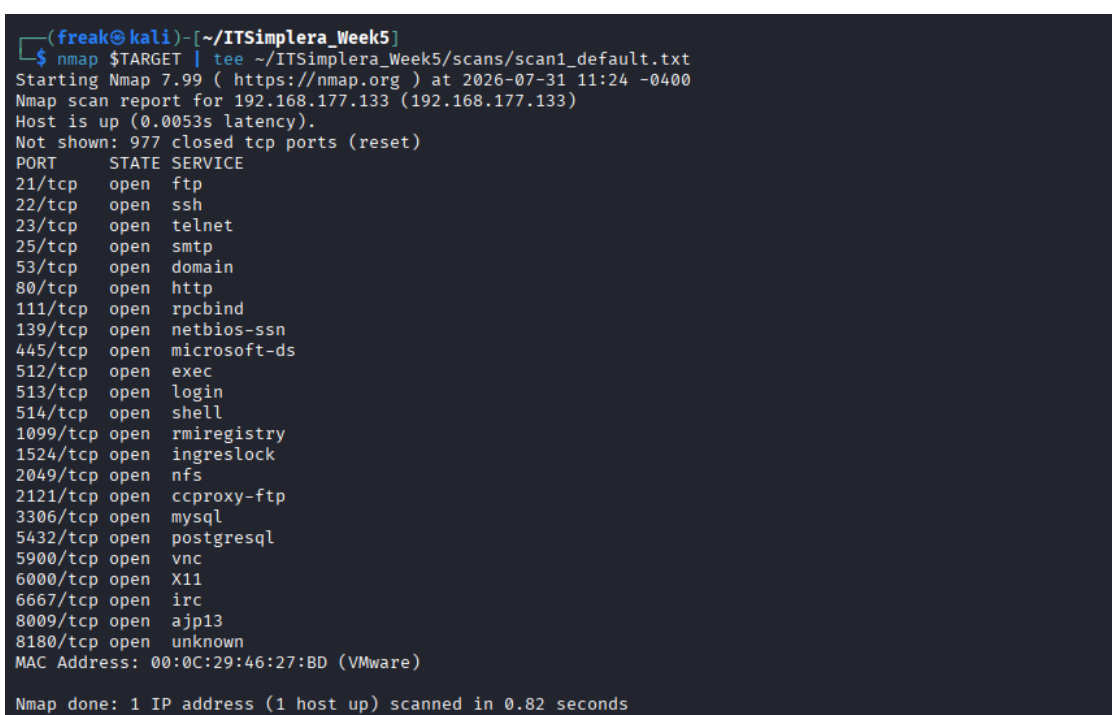
- nmap \$TARGET (default scan)
- nmap -sV \$TARGET (version detection)
- sudo nmap -O \$TARGET (OS detection)
- sudo nmap -A \$TARGET (aggressive scan)
- sudo nmap -p- \$TARGET (all 65535 ports)

A total of 23 open TCP ports were identified across all scans, consistent with the intentionally vulnerable services bundled with Metasploitable 2.



```
(freak@kali)-[~/ITSimplera_Week5]
$ TARGET=192.168.177.133
```

Figure 1 — Metasploitable 2 IP confirmation (ifconfig)



```
(freak@kali)-[~/ITSimplera_Week5]
$ nmap $TARGET | tee ~/ITSimplera_Week5/scans/scan1_default.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 11:24 -0400
Nmap scan report for 192.168.177.133 (192.168.177.133)
Host is up (0.0053s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:46:27:BD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.82 seconds
```

Figure 2 — Scan 1: Default Nmap scan

```

└─$ nmap -sV $TARGET | tee ~/ITSimplera_Week5/scans/scan2_version.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 11:24 -0400
Nmap scan report for 192.168.177.133 (192.168.177.133)
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:46:27:BD (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.58 seconds

```

Figure 3 — Scan 2: Nmap version detection (-sV)

```

(freak@kali)~$ sudo nmap -O $TARGET | tee ~/ITSimplera_Week5/scans/scan3_os.txt
[sudo] password for freak:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 11:27 -0400
Nmap scan report for 192.168.177.133 (192.168.177.133)
Host is up (0.0043s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:46:27:BD (VMware)
Device type: general purpose
Running: Linux 2.6.X

```

Figure 4 — Scan 3: Nmap OS detection (-O)

```

(freak@kali)~[~/ITSimplera_Week5]
$ sudo nmap -A $TARGET | tee ~/ITSimplera_Week5/scans/scan4_aggressive.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 11:28 -0400
Nmap scan report for 192.168.177.133 (192.168.177.133)
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.177.128
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5

```

Figure 5 — Scan 4: Aggressive scan (-A), part 1

```

|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-07-31T15:29:27+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain      ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp    open  rpcbind    2 (RPC #100000)
|_rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100003 2,3,4 2049/tcp nfs
|_100003 2,3,4 2049/udp nfs
|_100005 1,2,3 35845/tcp mountd
|_100005 1,2,3 55312/udp mountd
|_100021 1,3,4 50102/udp nlockmgr
|_100021 1,3,4 51622/tcp nlockmgr
|_100024 1 53062/udp status
|_100024 1 58834/tcp status
139/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

```

Figure 6 — Scan 4: Aggressive scan (-A), part 2

```

514/tcp    open  tcpwrapped
1099/tcp   open  java-rmi    GNU Classpath grmiregistry
1524/tcp   open  bindshell   Metasploitable root shell
2049/tcp   open  nfs         2-4 (RPC #100003)
2121/tcp   open  ftp         ProFTPD 1.3.1
3306/tcp   open  mysql       MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 9
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, Support41Auth, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, ConnectWithDatabase, LongColumnFlag, SupportsCompression
|_Status: Autocommit
|_Salt: h-ESPU"Dn"Xwm?1w'VJR
5432/tcp   open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-07-31T15:29:27+00:00; 0s from scanner time.
5900/tcp   open  vnc         VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp   open  X11         (access denied)
6667/tcp   open  irc         UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_lusers: 1
|_lservers: 0
|_server: irc.Metasploitable.LAN

```

Figure 7 — Scan 4: Aggressive scan (-A), part 3

```

| server: irc.Metasploitable.LAN
| version: Unreal3.2.8.1. irc.Metasploitable.LAN
| uptime: 0 days, 0:08:24
| source ident: nmap
| source host: C12AEF20.D78076F6.FFFA6D49.IP
| error: Closing Link: goakwklwz[192.168.177.128] (Quit: goakwklwz)
8009/tcp open  ajp13          Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http           Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
MAC Address: 00:0C:29:46:27:BD (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain

```

Figure 8 — Scan 4: Aggressive scan (-A), part 4

```

TRACEROUTE
HOP RTT      ADDRESS
1   1.34 ms  192.168.177.133 (192.168.177.133)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 77.69 seconds

```

Figure 9 — Scan 4: Aggressive scan (-A), summary

```

(freak@kali)-[~/ITSimplera_Week5/scans]
$ cd ~/ITSimplera_Week5/scans
$ sudo nmap -p- -T4 --stats-every 15s 192.168.177.133 | tee scan5_allports.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 12:24 -0400
Nmap scan report for 192.168.177.133 (192.168.177.133)
Host is up (0.0060s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13

```

Figure 10 — Scan 5: All-ports scan (-p-), part 1

```
512/tcp    open  exec
513/tcp    open  login
514/tcp    open  shell
1099/tcp   open  rmiregistry
1524/tcp   open  ingreslock
2049/tcp   open  nfs
2121/tcp   open  ccproxy-ftp
3306/tcp   open  mysql
3632/tcp   open  distccd
5432/tcp   open  postgresql
5900/tcp   open  vnc
6000/tcp   open  X11
6667/tcp   open  irc
6697/tcp   open  ircs-u
8009/tcp   open  ajp13
8180/tcp   open  unknown
8787/tcp   open  msgsrvr
33161/tcp  open  unknown
33451/tcp  open  unknown
44205/tcp  open  unknown
47493/tcp  open  unknown
MAC Address: 00:0C:29:46:27:BD (VMware)
```

```
Nmap done: 1 IP address (1 host up) scanned in 9.38 seconds
```

Figure 11 — Scan 5: All-ports scan (-p-), summary

Task 2 — Service Enumeration

The table below summarizes all open ports discovered, the protocol, service name, detected version, port status, and the general purpose of each service, derived from the Nmap version-detection scan (-sV).

Port	Proto	Service	Version	Status	Purpose
21	TCP	FTP	vsftpd 2.3.4	Open	File transfer service
22	TCP	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	Open	Secure remote shell access
23	TCP	Telnet	Linux telnetd	Open	Unencrypted remote login
25	TCP	SMTP	Postfix smtpd	Open	Mail transfer agent
53	TCP	DNS	ISC BIND 9.4.2	Open	Domain name resolution
80	TCP	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2	Open	Web server
111	TCP	RPCbind	RPC #100000, v2	Open	RPC port mapper service
139	TCP	NetBIOS-SSN	Samba smbd 3.X-4.X	Open	Windows file/print sharing (NetBIOS)
445	TCP	Microsoft-DS/SMB	Samba smbd 3.X-4.X	Open	Windows file/print sharing (SMB)
512	TCP	Exec	Unidentified	Open	Remote process execution (rexec)
513	TCP	Login	OpenBSD/Solaris rlogind	Open	Remote login (rlogin)
514	TCP	Shell	tcpwrapped	Open	Remote shell (rsh)
1099	TCP	Java-RMI	GNU Classpath grmiregistry	Open	Java Remote Method Invocation registry
1524	TCP	Bindshell	Metasploitable root shell	Open	Backdoor root shell (intentional)
2049	TCP	NFS	RPC #100003, v2-4	Open	Network File System sharing
2121	TCP	FTP	ProFTPD 1.3.1	Open	Secondary FTP service
3306	TCP	MySQL	MySQL 5.0.51a-3ubuntu5	Open	Relational database service
5432	TCP	PostgreSQL	PostgreSQL DB 8.3.0-8.3.7	Open	Relational database service
5900	TCP	VNC	VNC protocol 3.3	Open	Remote desktop access
6000	TCP	X11	Access denied	Open	X Window System display server
6667	TCP	IRC	UnrealIRCd	Open	Internet Relay Chat server
8009	TCP	AJP13	Apache JServ Protocol v1.3	Open	Apache-Tomcat connector

Port	Proto	Service	Version	Status	Purpose
8180	TCP	HTTP	Apache Tomcat/Coyote JSP engine 1.1	Open	Java web application server

Total open ports identified: 23.

Task 3 — Vulnerability Research (CVE Analysis)

Six services were selected for vulnerability research (exceeding the minimum requirement of three), prioritizing the most impactful and well-documented weaknesses present in Metasploitable 2.

Service	CVE ID	Vulnerability	CVSS	Severity	Description	Recommended Fix
vsftpd 2.3.4 (21)	CVE-2011-2523	vsftpd 2.3.4 Backdoor Command Execution	10.0	Critical	A malicious backdoor was inserted into the vsftpd 2.3.4 source archive. Sending a username containing a smiley-face sequence during FTP login opens a listening root shell on TCP 6200.	Upgrade to a verified vsftpd build; disable anonymous FTP; verify package signatures; monitor for listeners on port 6200.
OpenSSH 4.7p1 (22)	CVE-2008-5161	OpenSSH CBC Mode Information Disclosure	2.6	Low-Medium	Weakness in OpenSSH's CBC mode implementation allows partial plaintext recovery from an encrypted session via a man-in-the-middle attack.	Upgrade OpenSSH; disable CBC ciphers in sshd_config; enforce protocol 2 and key-based authentication.
Samba smbld (139/445)	CVE-2007-2447	Samba "username map script" Command Injection	10.0	Critical	The username map script option allows shell metacharacters in the login username to be executed unsanitized, enabling unauthenticated remote command execution as root.	Upgrade Samba; disable username map script; restrict SMB access via firewall to trusted hosts only.
UnrealIRCd (6667)	CVE-2010-2075	UnrealIRCd 3.2.8.1 Backdoor Command Execution	10.0	Critical	A trojanized UnrealIRCd source distribution contained a backdoor allowing any remote user to execute arbitrary commands without authentication.	Redownload from verified source; validate file hashes; upgrade to a clean current release; monitor daemon behavior.
Apache Tomcat (8180)	CVE-2009-3843 (representative)	Default/Weak Manager Credentials -> WAR Deployment RCE	7.5-9.0	High	Default or weak manager console credentials allow an attacker to deploy a malicious WAR file via /manager/html, achieving remote code execution.	Change default credentials immediately; restrict manager console to trusted IPs; disable manager app if unused.
Telnet (23)	N/A (protocol-level)	Cleartext Authentication & Session Exposure	N/A	High	Telnet transmits all credentials and session data unencrypted, allowing trivial interception via network sniffing.	Disable Telnet; replace with SSH; if legacy use is required, restrict to an isolated management VLAN.

Task 4 — Scan Comparison

Scan	Speed	Depth of Information	Real-World Applicability	Advantages	Disadvantages
Scan 1 — Default (nmap \$TARGET)	Fastest (0.82s)	Low — port + state + guessed service name	Quick initial sweep to confirm live hosts/ports	Very fast, low footprint, good first-pass recon	No version/OS info; service names are guesses
Scan 2 — Version Detection (-sV)	Moderate (70.58s)	Medium-High — confirms service + version banners	Core to real assessments; drives CVE matching	Enables accurate CVE research; reveals outdated software	Slower; probes can be evaded or return unknown
Scan 3 — OS Detection (-O)	Fast-Moderate	Medium — OS family/kernel only	Tailors exploits/hardening to correct platform	Scopes environment for patch levels	Requires root; can misfire on filtered hosts
Scan 4 — Aggressive (-A)	Slowest of targeted scans	Very High — version, OS, NSE scripts, traceroute combined	Best one-shot scan for authorized pentests	Most complete data in a single command	Very noisy; easily detected by IDS/IPS; long runtime
Scan 5 — All Ports (-p-)	Very slow (full sweep)	High breadth — finds ports outside top-1000	Essential; services can run on non-standard ports	Guarantees no open port is missed	Time-consuming; needs a follow-up -sV pass

Key Observations

- Fastest / lightest footprint: Scan 1 (Default) — best for stealthy or time-constrained recon.
- Most information-dense: Scan 4 (Aggressive) — combines version, OS, and script-based enumeration.
- Most critical for real-world coverage: Scan 5 (All Ports) — non-standard port placements are common in production and attacker environments.
- Recommended workflow: Scan 1 for triage -> Scan 5 for full port coverage -> Scan 2 for version data on discovered ports -> Scan 3/4 for OS and deep detail.

Task 5 — Security Analysis & Remediation Recommendations

For each significant finding, the table below documents the security risk, a realistic attack scenario, assessed risk level with justification, recommended remediation, verification method, and supporting reference, in the format required by the assignment deliverable.

Open Port / Service	Security Risk	Attack Scenario	Risk Level	Remediation	Verification Method	Reference
FTP — vsftpd 2.3.4 (21)	Backdoored FTP daemon allows unauthenticated root shell	Attacker sends a crafted username during login, triggering a listener on port 6200 that grants root access	Critical	1) Replace with verified vsftpd build 2) Disable anonymous FTP 3) Firewall port 21 to trusted hosts 4) Monitor for listeners on 6200	Re-scan port 6200 after patching; verify package signature/hash	CIS Benchmarks; NIST SP 800-53 (SI-2)
SSH — OpenSSH 4.7p1 (22)	CBC-mode cipher weakness allows partial plaintext recovery	Attacker positioned as MITM intercepts SSH session and recovers fragments of encrypted traffic	Medium	1) Upgrade OpenSSH 2) Disable CBC ciphers in sshd_config 3) Enforce key-based authentication	Run ssh -Q cipher to confirm CBC removed; re-test with nmap ssh2-enum-algos	NIST SP 800-53 (SC-13); OpenSSH advisories
SMB — Samba smbd (139/445)	Command injection via username map script option	Attacker injects shell metacharacters into the SMB login username, achieving unauthenticated RCE as root	Critical	1) Upgrade Samba 2) Disable username map script 3) Restrict SMB to internal trusted subnet via firewall	Confirm patched version via smbclient -L; re-scan with nmap smb-vuln* scripts	CIS Benchmarks (SMB hardening); Samba advisories
IRC — UnrealIRCd (6667)	Trojanized backdoor allows unauthenticated command execution	Attacker sends a crafted IRC message that triggers the backdoor, executing arbitrary OS commands	Critical	1) Redownload from official verified source 2) Validate file hash before deployment 3) Decommission if not required	Diff installed binary hash against official release; monitor for anomalous outbound connections	NIST SP 800-161; UnrealIRCd security notice
HTTP — Apache Tomcat (8180)	Default/weak manager console credentials	Attacker logs into /manager/html with default credentials and deploys a malicious WAR file for RCE	High	1) Change default manager credentials 2) Restrict manager console to trusted IPs 3) Disable manager app if unused	Attempt login with known default credentials post-fix to confirm rejection; review access logs	OWASP Top 10 (A07); Apache Tomcat Security Guide

Open Port / Service	Security Risk	Attack Scenario	Risk Level	Remediation	Verification Method	Reference
Telnet (23)	Cleartext authentication and session data	Attacker sniffs network traffic to capture credentials transmitted in plaintext	High	1) Disable Telnet entirely 2) Replace with SSH 3) Restrict to isolated management VLAN if legacy use required	Confirm port 23 closed via re-scan; verify SSH is the only remote-shell service exposed	NIST SP 800-53 (SC-8); CIS Benchmarks

Network Diagram — Attack Surface

The diagram below illustrates the lab topology, showing the attacker (Kali Linux) and target (Metasploitable 2) hosts on the isolated VMware lab network, along with the full set of open ports and services discovered during enumeration.

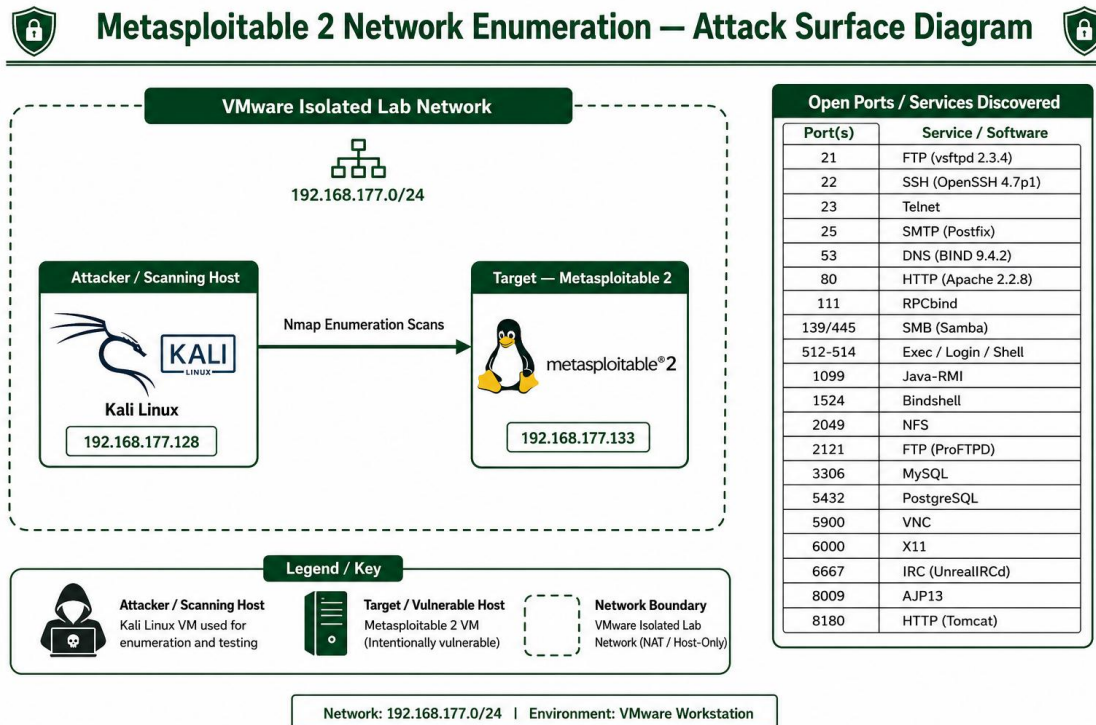


Figure 12 — Metasploitable 2 Network Enumeration Attack Surface Diagram

Challenges Faced

- Distinguishing genuine open services from Metasploitable's intentionally backdoored services required cross-referencing scan banners against known CVE databases rather than assuming default version behavior.
- The all-ports scan (-p-) took considerably longer than the targeted scans, requiring careful sequencing so each scan could complete and be captured cleanly before starting the next.
- Some services (e.g., port 512 exec and port 514 shell) returned ambiguous or unidentified version banners, requiring additional research to determine their standard purpose and associated risk.
- Mapping each finding to an appropriate, credible reference (CIS, NIST, OWASP, or vendor advisory) for every row of the Task 5 table required verifying each source rather than relying on a single blanket reference.

Conclusion

This assessment successfully enumerated the Metasploitable 2 target using five distinct Nmap scanning techniques, identifying 23 open ports and their associated services. Vulnerability research confirmed that several of these services contain critical, well-documented CVEs — including two intentionally embedded backdoors (vsftpd 2.3.4 and UnrealIRCd) that permit unauthenticated remote code execution.

The comparative analysis of scan types demonstrated the trade-offs between speed and depth of information, reinforcing that a layered scanning methodology (broad triage, full port coverage, then targeted version/OS detection) mirrors real-world professional practice. The security analysis and remediation table translates each finding into actionable guidance grounded in recognized frameworks (NIST, CIS, OWASP), providing a practical basis for hardening the environment.

Overall, this exercise reinforced core skills directly applicable to entry-level cybersecurity roles such as SOC Analyst, Vulnerability Assessment Analyst, and Penetration Tester — specifically, structured enumeration, evidence-based reporting, and translating technical findings into risk-prioritized remediation recommendations.

References

- National Institute of Standards and Technology (NIST) — Special Publication 800-53, Security and Privacy Controls.
- Center for Internet Security (CIS) — CIS Benchmarks for Linux, Samba, and SSH hardening.
- OWASP Foundation — OWASP Top 10 (2021), A07: Identification and Authentication Failures.
- National Vulnerability Database (NVD) — CVE-2011-2523, CVE-2008-5161, CVE-2007-2447, CVE-2010-2075, CVE-2009-3843.
- Apache Software Foundation — Apache Tomcat Security Guide.
- Rapid7 / Metasploitable 2 Documentation.
- Nmap.org — Official Nmap Reference Guide.